UNIVERSITI TEKNOLOGI MARA
MARKING SCHEME

COURSE	:	COMPUTER SECURITY
COURSE CODE	:	CSC662
EXAMINATION	:	OCTOBER 2026 (MOCK)
TIME	:	3 HOURS

MARKING SCHEME NOTES

1. This marking scheme accompanies the CSC662 mock paper (October 2026). Computed answers show working; theory answers are supported by lecture slides (not lecturer-marked) with a verbatim quote and slide citation.

2. Supported theory marking points quote the lecture decks; any unresolved slot would remain a visible placeholder.

3. Part A = 10 x (2 + 6); Part B = 2 x (5 + 5); total = 100 marks.

4. Computed: 1 slot(s). Supported theory: 23 slots. Placeholders: 0.
Questions and answers are for local study use only.

5. Near-copy rejection used all 35 past papers; style widening is recorded per slot.

FOR MARKERS' USE ONLY

This marking scheme consists of 16 printed pages

© Hak Cipta Universiti Teknologi MARA

CSC662 - MARKING SCHEME (MOCK OCTOBER 2026)

Labels: computed / supported by lecture slides (not lecturer-marked) / placeholder. No official marking scheme exists for the real CSC662 papers; this is generated for the mock.

Part A: 10 x (2 + 6) = 80 marks. Part B: 2 x (5 + 5) = 20 marks. Total: 100 marks. Slots: 1 computed, 23 supported by lecture slides, 0 placeholder.

Methods: computed answers use verified solvers. Theory answers are supported by lecture slides (not lecturer-marked). Each marking point carries a verbatim quote, a deck/slide/chunk citation and a term-overlap score; low overlap is flagged for human review. Sources are restricted to the slot topic's allowed decks, and a slide is not reused across questions where an alternative exists.

PART A - QUESTION 1

A1a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List TWO (2) typical locations where IDS sensors should be placed to defend valuable assets.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	Just inside the firewall	"Typical locations of IDS sensors Just inside the firewall"	062 - Intrusion Detection System, slide 7	062 - Intrusion Detection System::s07::1	1.00
2	On the DMZ	"Typical locations of IDS sensors Just inside the firewall On the DMZ"	062 - Intrusion Detection System, slide 7	062 - Intrusion Detection System::s07::1	1.00

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 062 - Intrusion Detection System, slide 7

A1b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain six preventive network security mechanisms, focusing on firewalls, proxy servers, segmentation, VPNs, ZTNA, and IDS/IPS, describing how each protects an organization's network.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	Firewalls control incoming and outgoing traffic based on predetermined security policies.	"Control incoming and outgoing traffic on network with predetermined security policies."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.78
2	Proxy servers act as a firewall and web filter to improve data security and network performance.	"Proxy servers act as a firewall and web filter, provide shared network connections, and cache data to speed up common requests."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.73
3	Network segmentation creates boundaries between segments where assets share a common function or risk.	"Boundaries between network segments where computing assets within the segment have a common function, risk or role within an organization."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.75
4	Remote Access VPN provides secure access to the	"Provides remote and secure access to an organization network to	061 - Network Security, slide 4	061 - Network Security::s04::1	0.90

© Hak Cipta Universiti Teknologi MARA

	organization network for individual hosts or clients.	individual hosts or clients"			
5	Zero Trust Network Access ensures users only have permissions required to fulfill their specific role.	"A user should only has access and permission that required to fulfill the role"	061 - Network Security, slide 4	061 - Network Security::s04::1	0.42 LOW
6	Intrusion Detection/Prevention Systems detect or prevent attacks such as brute force and Denial-of-Service.	"To detect or prevent the network security attacks such as brute force attacks, Denial-of-Service attacks and exploits of network vulnerabilities."	061 - Network Security, slide 4	061 - Network Security::s04::1	0.67

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 061 - Network Security, slide 3; 061 - Network Security, slide 4

PART A - QUESTION 2

A2a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the fundamental mechanism of a substitution cipher and identify the cryptographic principle it corresponds to.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	Substitution ciphers operate by replacing plain-text letters with other letters to produce cipher-text.	"In substitution ciphers, we replace the plain-text letters with other letters The resulting text is the cipher-text"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s04::1	0.70
2	This method aligns with Shannon's principle of confusion.	"Corresponds to Shannon's principle of confusion"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s04::1	0.60

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 031 - Classical Cryptography, slide 4

A2b - 6 marks - computed - matches lecture slide 15 (standard tableau)

Question:

Decrypt the following ciphertext using the Vigenere cipher with the key CIPHER. Use the standard 26 x 26 Vigenere tableau, writing the key over the message and repeating it as necessary.
UMRBVVNWVPREQE

Answer: SECURELOGINNOW

The 26 x 26 Vigenere tableau is printed in the question paper.

Working:

```
Standard 26 x 26 tableau, A=0; key repeated over the ciphertext.
Ciphertext: UMRBVVNWVPREQE
Key:        CIPHERCIPHERCI
Letter-by-letter: C - K mod 26 = P
  U (20) - C ( 2) = 18 -> S
  M (12) - I ( 8) =  4 -> E
  R (17) - P (15) =  2 -> C
  B ( 1) - H ( 7) = 20 -> U
  V (21) - E ( 4) = 17 -> R
```

```
  V (21) - R (17) =  4 -> E
  N (13) - C ( 2) = 11 -> L
  W (22) - I ( 8) = 14 -> O
  V (21) - P (15) =  6 -> G
  P (15) - H ( 7) =  8 -> I
  R (17) - E ( 4) = 13 -> N
  E ( 4) - R (17) = 13 -> N
  Q (16) - C ( 2) = 14 -> O
  E ( 4) - I ( 8) = 22 -> W
Plaintext:  SECURELOGINNOW
```

Suggested marks: 1 mark for the key/table setup; 4 marks for the letter-by-letter working; 1 mark for the complete answer.

Confidence: computed - matches lecture slide 15 (standard tableau).

PART A - QUESTION 3

A3a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List TWO (2) key sources or characteristics of software insecurity as described in the lecture.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	The attacker's ability to modify system resources critical for program execution, such as instruction pointers or function call addresses.	"Software insecurity stems from attacker's ability to modify system resources criticial for program execution, e.g. instruction pointer, function call addresses, interrupt addresses, etc."	051 - Software Security, slide 30	051 - Software Security::s30::1	0.79
2	Failed validation of user input.	"One of the key sources for software insecurity is failed validation of user input."	051 - Software Security, slide 30	051 - Software Security::s30::1	1.00

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.

Citations: 051 - Software Security, slide 30

A3b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the key security mechanisms and architectural features of Windows operating systems, including their evolution, management structures, and potential vulnerabilities.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	Windows systems utilize complex security mechanisms for managing user accounts, objects, and access control.	"Windows systems contain complex security mechanisms for user account and object management as well as access control."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.67
2	Discretionary Access Control Systems (DACS) allow for fine-grained access control over heterogeneous entities within the OS and applications.	"DACS enable fine-grained access control of heterogeneous entities in Windows itself as well as applications."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.54

© Hak Cipta Universiti Teknologi MARA

3	The complexity of these security mechanisms creates a vulnerability where misconfiguration or implementation bugs can lead to severe security incidents.	"The complexity of Windows security mechanisms is also its enemy: misconfiguration as well as implementation bugs may lead to severe security incidents."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.61
4	Active Directory, introduced in Windows 2000, serves as an LDAP-like directory service for organizing system resources such as users, groups, and security policies.	"Active directory introduced in Windows 2000 is an LDAP-like directory service for organization of system resources:"	041 - Windows Security, slide 6	041 - Windows Security::s06::1	0.59
5	Security milestones include Vista's introduction of non-admin-by-default settings, firewalls, and Data Execution Prevention (DEP).	"Vista (2007): no "admin-by-default", firewall, DEP"	041 - Windows Security, slide 2	041 - Windows Security::s02::1	0.29 LOW
6	Subjects in Windows are active entities like processes and threads, with their security credentials stored in tokens that provide principal/subject mapping.	"Security credentials for a subject are stored in a token. Tokens provide a principal/subject mapping and may contain additional security attributes."	041 - Windows Security, slide 11	041 - Windows Security::s11::1	0.53

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 041 - Windows Security, slide 11; 041 - Windows Security, slide 2; 041 - Windows Security, slide 21; 041 - Windows Security, slide 6

PART A - QUESTION 4

A4a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) characteristics of Trojan horses and computer worms as described in the lecture slides.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	Trojan horses masquerade as helpful or harmless programs to steal data or install further malware.	"They usually masquerade as helpful or harmless programs and begin to steal private data, delete files, log keystrokes or provide an opening for further malware to get installed."	051 - Software Security, slide 12	051 - Software Security::s12::1	0.73
2	Computer worms exploit system vulnerabilities to corrupt files, consume	"Worms are another type of malicious software that exploit a vulnerability in the computer system to	051 - Software Security, slide 12	051 - Software Security::s12::1	0.75

© Hak Cipta Universiti Teknologi MARA

	bandwidth, and take control of the host.	cause harm. They usually corrupt or delete critical files, consume excess bandwidth and often put the computer under control of the worm author."			

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 12

A4b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss six (6) distinct malware attack techniques or propagation methods described in the lecture slides.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	Viruses spread via boot sector infection, as seen in early examples like Elk Cloner and Brain Virus.	"A program spread via boot sector infection"	051 - Software Security, slide 7	051 - Software Security::s07::1	0.36 LOW
2	Worms propagate across networks by exploiting remote execution vulnerabilities, such as those in sendmail.	"Used a debugging feature of sendmail (remote execution)"	051 - Software Security, slide 7	051 - Software Security::s07::1	0.30 LOW
3	Executable viruses append their code to legitimate programs and modify headers to hijack the entry point.	"Append a virus body to a program"	051 - Software Security, slide 10	051 - Software Security::s10::1	0.09 LOW
4	Rootkits are installed after vulnerability detection to mask malicious processes and maintain privileged access.	"They are usually installed after a vulnerability has been found and detected so that the infected computer continues to be under the control of the malware author."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.27 LOW
5	Spyware steals sensitive user data including logins, passwords, and keystrokes.	"They steal user logins and passwords, document sites visited, log keystrokes and even redirect browsers to unwanted sites."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.44 LOW
6	XSS attacks allow arbitrary JavaScript execution in a victim's browser through unfiltered user input.	"Allows execution of arbitrary Javascript in user's browser."	052 - Web Security, slide 13	052 - Web Security::s13::1	0.42 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).

© Hak Cipta Universiti Teknologi MARA

Citations: 051 - Software Security, slide 10; 051 - Software Security, slide 13; 051 - Software Security, slide 7; 052 - Web Security, slide 13

PART A - QUESTION 5

A5a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the distinction between morals and laws in the context of computer security ethics.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	Morals are defined as traditions of belief about right and wrong conduct that form the bedrock of social behavior.	"Morals are traditions of belief about right and wrong conduct and "doing what is morally right" is the bedrock of our social behavior"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	0.83
2	Laws are formal rules of conduct imposed on subjects or citizens by a sovereign authority such as a government.	"Laws are formal rules of conduct that a sovereign authority, such as a government, imposes on its subjects or citizens"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	0.91

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 5

A5b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State six principles from the ACM Code of Ethics that guide a computing professional's conduct regarding society, honesty, fairness, intellectual property, privacy, and confidentiality.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	Contribute to society and human well-being, acknowledging all people as stakeholders.	"Contribute to society and to human well-being, acknowledging that all people are stakeholders in computing."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	1.00
2	Be honest and trustworthy in professional interactions.	"Be honest and trustworthy."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.50
3	Be fair and take action not to discriminate.	"Be fair and take action not to discriminate."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	1.00
4	Respect the work required to produce new ideas, inventions, creative works, and computing artifacts.	"Respect the work required to produce new ideas, inventions, creative works, and computing artifacts."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	1.00
5	Respect privacy.	"Respect privacy."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	1.00
6	Honor confidentiality.	"Honor confidentiality."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	1.00

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited

© Hak Cipta Universiti Teknologi MARA

lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 11

PART A - QUESTION 6

A6a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the two main stages of the biometric authentication process and list one key step involved in each stage.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	The first stage is Identification, which involves acquisition, creation of master characteristics, and storage of master characteristics.	"Identification Stage Acquisition Creation of Master characteristics Storage of Master characteristics"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1	0.75
2	The second stage is Authentication, which involves acquisition, comparison, and decision.	"Authentication Stage Acquisition(s) Comparison Decision"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1	0.71

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 5

A6b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the definition of a biometric and its two main categories, providing specific examples for each category and one disadvantage associated with fingerprint recognition.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	Definition: A biometric is a physiological or behavioural characteristic that distinguishes individuals.	""A biometric is a physiological or behavioural characteristic of a human being that can distinguish one person from another and that theoretically can be used for identification or verification of identity.""	072 - Biometrics and Authentication, slide 2	072 - Biometrics and Authentication::s02::1	0.50
2	Category 1: Psychological biometrics include traits such as Iris, Fingerprints, Hand, Retinal and Face recognition.	"Psychological: Iris, Fingerprints, Hand, Retinal and Face recognition"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.58
3	Category 2: Behavioural biometrics include traits such as Voice, Typing pattern, and Signature.	"Behavioural: Voice, Typing pattern, Signature"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.50
4	Disadvantage:	"Racial issues"	072 - Biometrics and Authentication,	072 - Biometrics and Authentication::s07::1	0.33 LOW

© Hak Cipta Universiti Teknologi MARA

	Fingerprint systems suffer from racial issues.		slide 7		
5	Disadvantage: Fingerprint systems are affected by dirt, grime and wounds.	"Dirt , grime and wounds"	072 - Biometrics and Authentication, slide 7	072 - Biometrics and Authentication::s07::1	0.43 LOW
6	Disadvantage: Fingerprint systems require careful placement of finger to work correctly.	"Placement of finger"	072 - Biometrics and Authentication, slide 7	072 - Biometrics and Authentication::s07::1	0.22 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 2; 072 - Biometrics and Authentication, slide 4; 072 - Biometrics and Authentication, slide 7

PART A - QUESTION 7

A7a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State the primary security focus of the Bell-La Padula (BLP) model and the Biba model.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	The BLP model focuses on access control.	"Bell-La Padula (BLP) model: access control only"	024 - Formal Security Model, slide 5	024 - Formal Security Model::s05::1	0.80
2	The Biba model focuses on integrity verification.	"Biba model: additional integrity verification"	024 - Formal Security Model, slide 5	024 - Formal Security Model::s05::1	0.80

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 024 - Formal Security Model, slide 5

A7b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe the characteristics and trade-offs of Access Control Matrix (ACM), Access Control List (ACL), and capability structures in access control systems.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	The Access Control Matrix is a basic structure that offers clarity of definition and ease of verification.	"ACM is a basic control structure. Advantages: clarity of definition easy to verify"	023 - Access Control and Authorization, slide 8	023 - Access Control and Authorization::s08::1	0.40 LOW
2	The primary disadvantages of the Access Control Matrix are its poor scalability and difficulty in handling changes.	"Disadvantages: poor scalability poor handling of changes"	023 - Access Control and Authorization, slide 8	023 - Access Control and Authorization::s08::1	0.56
3	Access Control Lists provide an object-centered description of access rights,	"ACL is an object-centered description of access rights:"	023 - Access Control and Authorization, slide 10	023 - Access Control and Authorization::s10::1	0.46 LOW

© Hak Cipta Universiti Teknologi MARA

	making it easy to view rights for a specific object.				
4	A key advantage of ACLs is the relative easiness of management when using abstractions such as groups or roles.	"relative easiness of management using abstractions"	023 - Access Control and Authorization, slide 10	023 - Access Control and Authorization::s10::1	0.40 LOW
5	Capabilities are listed as one of the common practical access control instruments alongside ACLs and various abstractions.	"Most common practical access control instruments are ACLs, capabilities and various abstractions."	023 - Access Control and Authorization, slide 18	023 - Access Control and Authorization::s18::1	0.82
6	Capabilities are also referred to as C-Lists within the formal structures used to implement access policies.	"access control matrix (ACM) Capabilities (C-List)"	023 - Access Control and Authorization, slide 7	023 - Access Control and Authorization::s07::1	0.18 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 023 - Access Control and Authorization, slide 10; 023 - Access Control and Authorization, slide 18; 023 - Access Control and Authorization, slide 7; 023 - Access Control and Authorization, slide 8

PART A - QUESTION 8

A8a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain two ethical responsibilities of a computing professional regarding the evaluation and public understanding of technology impacts.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	Professionals must provide thorough evaluations of computer systems including analysis of possible risks.	"Give comprehensive and thorough evaluations of computer systems and their impacts, including analysis of possible risks."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.73
2	Professionals should foster public awareness of computing technologies and their consequences.	"Foster public awareness and understanding of computing, related technologies, and their consequences."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.75

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 12

A8b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Refer to your answer in (a). Discuss how professional codes of ethics and documented behavioral standards guide organizational responsibility regarding privacy and conduct.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	Ethics is defined as a documented set of acceptable behaviors for professional or social groups.	"Documented set of acceptable behaviors for professional or social groups."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1	0.78
2	These ethical standards are defined by the specific group rather than imposed externally.	"Defined by the group."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1	0.25 LOW
3	The code identifies specific actions as appropriate or inappropriate for members.	"Identifies specific actions as appropriate or inappropriate."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1	0.67
4	The Association of Computing Machinery maintains a code of ethics and professional conduct.	"Association of Computing Machinery ACM (founded 1947) has a code of ethics and professional conduct."	071 - Ethics and Computer Security, slide 7	071 - Ethics and Computer Security::s07::1	0.88
5	The Association of Information Technology Professionals provides information on relevant IT issues.	"provides quality IT-related education, information on relevant IT issues,"	071 - Ethics and Computer Security, slide 7	071 - Ethics and Computer Security::s07::1	0.57
6	AITP offers forums for networking with experienced peers and other IT professionals.	"forums for networking with experienced peers and other IT professionals."	071 - Ethics and Computer Security, slide 7	071 - Ethics and Computer Security::s07::1	0.75

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 6; 071 - Ethics and Computer Security, slide 7

PART A - QUESTION 9

A9a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how the threat classes of Disclosure and Usurpation specifically impact the Confidentiality and Availability objectives of the CIA triad.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	Disclosure involves unauthorized access to information, which directly compromises confidentiality services.	"Disclosure - unauthorized access to information snooping, sniffing, wiretapping Confidentiality services counter this threat"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.67
2	Usurpation involves unauthorized control of a system part, such as denial of service, which	"Usurpation - unauthorized control of some part of a system Modification, spoofing, delay, denial of service Availability services	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.75

© Hak Cipta Universiti Teknologi MARA

	impacts availability services.	counter this threat"			

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 011 - Introduction to Computer Security, slide 10

A9b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State six (6) distinct characteristics or impacts of the Samy worm and Cross-Site Scripting (XSS) attacks as described in the lecture slides.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	The attack involves injecting JavaScript into a user profile using document.body.innerHTML.	"Inject Javascript into a user profile using document.body.innerHTML"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.60
2	The attacker retrieves the list of the victim's friends by performing a GET request on their profile.	"Get the list of user's heros by using a GET on a user profile"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.12 LOW
3	The malware adds itself to the victim's friend list via an XML-HTTP request to the addFriends page.	"Add Samy as a field by performing XML-HTTP on the addFriends page"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.36 LOW
4	Any user visiting an infected profile automatically gets their own profile and friends list infected.	"Any user who visits an infected user's page will gets profile infected with Javascript and his friends list infected with Samy"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.56
5	In XSS, malicious scripts are dynamically injected into the response via a user request rather than originating from the web server.	"In a XSS attack, Javascript does not originate from a web server but is dynamically injected into it via a user request a following reflection from a third-party, a "cross-site"."	052 - Web Security, slide 14	052 - Web Security::s14::1	0.60
6	The execution of the malicious script causes the victim's browser to send their cookies to the attacker's server.	"The victim's browser executes the malicious script inside the response, sending the victim's cookies to the attacker's server."	052 - Web Security, slide 16	052 - Web Security::s16::1	0.70

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 052 - Web Security, slide 14; 052 - Web Security, slide 15; 052 - Web Security, slide 16

PART A - QUESTION 10

A10a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) limitations of Misuse Detection Systems in identifying attacks.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	They are ineffective against unknown attack methods.	"but they are of little use for unknown attack methods"	062 - Intrusion Detection System, slide 17	062 - Intrusion Detection System::s17::1	0.67
2	They cannot detect denial of service attacks.	"They can't detect denail of service attacks"	062 - Intrusion Detection System, slide 21	062 - Intrusion Detection System::s21::1	0.67

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.

© Hak Cipta Universiti Teknologi MARA

Citations: 062 - Intrusion Detection System, slide 17; 062 - Intrusion Detection System, slide 21

A10b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss six (6) distinct software threats or malware propagation techniques described in the lecture slides.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	Modification of program code is a software threat.	"Modification of program code"	051 - Software Security, slide 2	051 - Software Security::s02::1	0.40 LOW
2	Viruses and self-replicating code are identified as software threats.	"Viruses and self-replicating code"	051 - Software Security, slide 2	051 - Software Security::s02::1	0.57
3	OS and API hooking represents a method to compromise software integrity.	"OS and API hooking"	051 - Software Security, slide 2	051 - Software Security::s02::1	0.29 LOW
4	Control flow hijacking is a technique used to alter program execution.	"Control flow hijacking"	051 - Software Security, slide 2	051 - Software Security::s02::1	0.25 LOW
5	Buffer overflow vulnerabilities allow attackers to inject malicious code.	"Buffer overflow"	051 - Software Security, slide 2	051 - Software Security::s02::1	0.12 LOW
6	SQL injection is a specific type of code injection attack.	"SQL injection"	051 - Software Security, slide 2	051 - Software Security::s02::1	0.50

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 051 - Software Security, slide 2

PART B - QUESTION 1

B1a - 5 marks - supported by lecture slides (not lecturer-marked)

Scenario:

A security architect is designing a platform that relies on hardware-based trust. The design specifies the use of a Trusted Platform Module (TPM) to establish a chain of trust from boot time through to application execution, ensuring the integrity of the system.

Question:

State five key characteristics or functions of the TPM and its role in establishing a chain of trust.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	The TPM is defined as a tamper-resistant hardware module mounted in a platform.	"Trusted Platform Module (TPM): a tamper-resistant hardware module mounted in a platform."	073 - Trusted Computing, slide 6	073 - Trusted Computing::s06::1	0.88
2	The TPM is responsible for measurement, protected storage, integrity reporting, and policy enforcement.	"Responsible for: measurement, (protected) storage, (integrity) reporting and policy enforcement."	073 - Trusted Computing, slide 6	073 - Trusted Computing::s06::1	0.89
3	In the chain of	"Each stage	073 - Trusted	073 - Trusted	0.67

© Hak Cipta Universiti Teknologi MARA

	trust, each stage measures and validates the next one.	measures and validates the next one"	Computing, slide 8	Computing::s08::1	
4	Measurements are stored in Platform Configuration Registers (PCRs) located on the TPM.	"Measurements go into Platform Configuration Registers (PCRs) on the TPM"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.75
5	The chain of trust begins with the hardware TPM and extends to software components like BIOS and kernel.	"The chain starts with the hardware TPM, then software: RTM,TPM Software Stack, BIOS, kernel"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.60

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 073 - Trusted Computing, slide 6; 073 - Trusted Computing, slide 8

B1b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss the components of the Next Generation Secure Computing Base (NGSCB) and their roles in establishing hardware-based trust within the scenario.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	Nexus acts as a security kernel that is authenticated on boot.	"Security kernel, authenticated on boot"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.67
2	Nexus provides an application interface to the TPM.	"Application interface to TPM"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.60
3	The Nexus Computing Agent (NCA) is a trusted software component.	"Trusted software component"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.33 LOW
4	The NCA runs in a trusted mode that communicates with Nexus.	"Runs in trusted mode that communicates with Nexus"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.83
5	Developers can create their own agents to run on the trusted platform.	"Developers can make their own agents to run on the trusted platform"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.88

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 073 - Trusted Computing, slide 14; 073 - Trusted Computing, slide 15

PART B - QUESTION 2

B2a - 5 marks - supported by lecture slides (not lecturer-marked)

Scenario:

A university IT department is reviewing its user authentication protocols to enhance security. The team focuses on strengthening password management practices and implementing controls to prevent unauthorized access through compromised credentials.

Question:

Explain five specific password security controls or policies that can be applied to protect user accounts and system integrity.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	Applying access control restrictions directly to the files where passwords are stored.	"Access control applied to password files"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.22 LOW
2	Automatically de-activating user accounts after a threshold of failed login attempts is reached.	"De-activation of accounts after multiple failed logins"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.30 LOW
3	Displaying the timestamp of the most recent successful login to alert users of potential compromise.	"Displaying the time of a last login"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.20 LOW
4	Ensuring passwords are never divulged over telephone lines to prevent social engineering attacks.	"never divulged over a telephone"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.36 LOW
5	Restricting password entry to only occur locally on the machine that the user physically controls.	"only entered locally on a machine it controls"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.40 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 022 - Identification and Authentication, slide 12

B2b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

In the scenario, explain five key aspects of Kerberos and Single Sign-On mechanisms that support secure authentication in distributed environments.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Term overlap
1	Kerberos ensures security against eavesdropping by preventing password transmission in clear text.	"Security against eavesdropping: no password transmission in clear text."	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1	0.70
2	Kerberos provides transparency so users are unaware of authentication steps beyond the initial login.	"Transparency: user is not aware of any authentication beyond an initial login."	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1	0.50
3	Single Sign-On solutions include client-server architectures such as Kerberos and	"Client-server architectures (Kerberos, Active Directory)"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.55

© Hak Cipta Universiti Teknologi MARA

	Active Directory.				
4	Smart cards serve as a physical 'something you have' alternative to passwords for user authentication.	"Something you have: smart cards, security tokens"	022 - Identification and Authentication, slide 9	022 - Identification and Authentication::s09::1	0.40 LOW
5	A limitation of Kerberos is that it introduces a single point of failure in the system.	"Single point of failure."	022 - Identification and Authentication, slide 23	022 - Identification and Authentication::s23::1	0.43 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 022 - Identification and Authentication, slide 16; 022 - Identification and Authentication, slide 18; 022 - Identification and Authentication, slide 23; 022 - Identification and Authentication, slide 9

End of marking scheme.

© Hak Cipta Universiti Teknologi MARA